

Upon starting using SQLMap, the first stop for new users is usually the program's help message. To help new users, there are two levels of help message listing:

- ```

Getting Started with SQLMap

dbcyph0n@htb[/htb]$ sqlmap -h

 __
 H
--['']----- {1.4.9#stable}
|_ -| . ["] | .' | . |
|__|_ [.]_||_|_|_|_|_|
 |_|V... |_| http://sqlmap.org

Usage: python3 sqlmap [options]

Options:
 -h, --help Show basic help message and exit
 -hh Show advanced help message and exit
 --version Show program's version number and exit
 -v VERBOSE Verbosity level: 0-6 (default 1)

Target:
 At least one of these options has to be provided to define the
 target(s)

 -u URL, --url=URL Target URL (e.g. "http://www.site.com/vuln.php?id=1")
 -g GOOGLEDORK Process Google dork results as target URLs
...SNIP...

```

- ```

Getting Started with SQLMap

dbcypn@htb[/htb]$ sqlmap -hh

  ____
  _H_
  --[ ]----- {1.4.9#stable}
 |_-| | . [|] | .'| . |
 |__|_ [|]_|_|_|_|_|_|_|
   |IV...   |_| http://sqlmap.org

Usage: python3 sqlmap [options]

Options:
  -h, --help            Show basic help message and exit
  -hh                   Show advanced help message and exit
  --version              Show program's version number and exit
  -v VERBOSE            Verbosity Level: 0-6 (default 1)

Target:
  At least one of these options has to be provided to define the
  target(s)

  -u URL, --url=URL     Target URL (e.g. "http://www.site.com/vuln.php?id=1")
  -d DIRECT              Connection string for direct database connection
  -l LOGFILE             Parse target(s) from Burp or WebScarab proxy log file
  -m BULKFILE            Scan multiple targets given in a textual file
  -r REQUESTFILE         Load HTTP request from a file
  -s SCAPEDBPK           Process ScapEdBPK results as target URLs

```

```

g .....
-c CONFIGFILE      Load options from a configuration INI file

```

Request:

These options can be used to specify how to connect to the target URL

```

-A AGENT, --user.. HTTP User-Agent header value
-H HEADER, --hea.. Extra header (e.g. "X-Forwarded-For: 127.0.0.1")
--method=METHOD Force usage of given HTTP method (e.g. PUT)
--data=DATA       Data string to be sent through POST (e.g. "id=1")
--param-del=PARA.. Character used for splitting parameter values (e.g. &)
--cookie=COOKIE   HTTP Cookie header value (e.g. "PHPSESSID=a8d127e..")
--cookie-del=COO.. Character used for splitting cookie values (e.g. ;)
...SNIP...

```

For more details, users are advised to consult the project's [wiki](#), as it represents the official manual for SQLMap's usage.

Basic Scenario

In a simple scenario, a penetration tester accesses the web page that accepts user input via a **GET** parameter (e.g., **id**). They then want to test if the web page is affected by the SQL injection vulnerability. If so, they would want to exploit it, retrieve as much information as possible from the back-end database, or even try to access the underlying file system and execute OS commands. An example SQLi vulnerable PHP code for this scenario would look as follows:

Code: **php**

```

$link = mysqli_connect($host, $username, $password, $database, 3306);
$sql = "SELECT * FROM users WHERE id = " . $_GET["id"] . " LIMIT 0, 1";
$result = mysqli_query($link, $sql);
if (!$result)
    die("<b>SQL error:</b> ". mysqli_error($link) . "<br>\n");

```

As error reporting is enabled for the vulnerable SQL query, there will be a database error returned as part of the web-server response in case of any SQL query execution problems. Such cases ease the process of SQLi detection, especially in case of manual parameter value tampering, as the resulting errors are easily recognized:

The screenshot shows a web browser window with the address bar displaying `http://www.example.com/vuln.php?id=1`. The page content includes a large heading "Lorem Ipsum" and a quote: "Neque porro quisquam est qui dolorem ipsum quia dolor sit amet, consectetur, adipisci velit..." followed by "There is no one who loves pain itself, who seeks after it and wants to have it, simply because it is pain...". Below this, there are two columns of text. The left column is titled "What is Lorem Ipsum?" and contains an "SQL error:" message: "You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near ' LIMIT 0, 1' at line 1". The right column is titled "Why do we use it?" and contains a paragraph explaining the purpose of Lorem Ipsum text.

To run SQLMap against this example, located at the example URL `http://www.example.com/vuln.php?id=1`, would look like the following:

```
dbcyph0n@htb[/htb]$ sqlmap -u "http://www.example.com/vuln.php?id=1" --batch
```

Note: in this case, option '-u' is used to provide the target URL, while the switch '--batch' is used for skipping any required user-input,

by automatically choosing using the default option.

[← Previous](#)[Next →](#)**+10 Streak pts**[✔ Mark Complete & Next](#) [Cheat Sheet](#)

Table of Contents

Getting Started

[SQLMap Overview](#)[Getting Started with SQLMap](#)[SQLMap Output Description](#)

Building Attacks

 [Running SQLMap on an HTTP Request](#)[Handling SQLMap Errors](#) [Attack Tuning](#)

Database Enumeration

 [Database Enumeration](#) [Advanced Database Enumeration](#)

Advanced SQLMap Usage

 [Bypassing Web Application Protections](#) [OS Exploitation](#)

Skills Assessment

 [Skills Assessment](#)

My Workstation

O F F L I N E

 [Start Instance](#) / 1 spawns left